

Nathaniel Abera

July 18, 2026

Legal issues in information security

A. The organization I've chosen is TeleMedica. The first ethical challenge the company faces is its duty to protect patients from foreseeable harm. By knowingly transmitting health data over the previously prohibited SSL 2.0 protocol (RFC 6176), the company places patient health information and data at risk even when it is aware of its potential weaknesses. This creates an ethical conflict between the convenience of conducting normal operations and maintaining a moral responsibility to safeguard the patients who trust TeleMedica's ability to keep their private information secure.

The second ethical challenge involves transparency and informed consent. Patients are not being clearly informed that their health data is being transferred across borders to TeleMedica's sister company, MediCom GmbH (TeleMedica, n.d.), under weak safeguards. This raises an ethical conundrum between the convenience of sharing data freely across locations and the patients' right to know how their sensitive information is handled and to consent to it.

B. One of the first consequences that TeleMedica may face is related to violations under HIPAA. Since the company handles electronic patient health information, a breach occurring while it was non-compliant would expose the privacy of its patients. This would make the company susceptible to heavy fines and penalties from the HHS Office for Civil Rights (U.S. Department of Health and Human Services, 2013) due to its negligence toward compliance requirements. They will also have to notify every patient that was affected by this breach as it is a requirement of the HITECH Act (U.S. Department of Health and Human Services, 2017).

The second consequence that TeleMedica may face is in regard to its GDPR requirements. Because TeleMedica shares data with its sister company MediCom GmbH in Berlin and operates in London, it falls under the requirements of the GDPR. If EU residents' health data were exposed in a breach because of non-compliance, TeleMedica could face GDPR penalties that would be extremely expensive, up to 4% of its global annual revenue (European Union, 2016), which would hurt the company financially.

The third consequence is in relation to the damage or loss of patient trust. If patient health records are breached, this automatically makes patients more skeptical of the telehealth company and causes them to look for better alternatives among competitors. Patients assume that the telehealth company will do its due diligence in protecting sensitive health information, but once that trust is broken, it is difficult to regain.

C. TeleMedica can improve its culture of compliance without SATE program by having a dedicated team or person that will constantly oversee if the company is being compliant under regulatory requirements. Because TeleMedica operates across multiple jurisdictions, it must ensure everything is compliant with HIPAA, GDPR, and CCPA all at once while having a team that constantly monitors that these requirements are being met. This team will report directly to company leadership, keeping leadership informed of the company's compliance status, allowing them to act quickly when anything out of the ordinary is found.

Another way is by creating a confidential communication channel dedicated to reporting any compliance concerns or violations employees may encounter, without fear of being punished for speaking up. This gives employees a safe way to communicate concerns without fear of losing their jobs, and it helps the company identify problems before they escalate into breaches or the heavy penalties that come with them.

D. The two ways that the SATE program will cultivate a culture of compliance within TeleMedica are shared awareness habits and normalizing accountability. The first way is by building a shared awareness of why security rules exist. When employees understand the reasoning behind compliance, it gives them a proper foundation to operate from. The employees must understand the legal obligations of the company under HIPAA and its duty to keep patients' health information safe.

The second way is by normalizing accountability across all employees. Training should make reporting incidents and following procedures the expected norm within the company. All employees need to hold themselves accountable as well as each other for compliance. As this becomes habitual amongst employees, it turns into a normal part of how TeleMedica operates rather than a policy that goes unenforced.

D1. The two ways that TeleMedica's leadership could support the SATE program are through visible participation and proper resourcing. Leadership should be completing the same training as other employees and they should openly communicate its importance. This will show that compliance is a requirement that applies to every employee within the company and not to be

something that can be overlooked. This kind of commitment reinforces the program's credibility and encourages employees to take it seriously.

The second way leadership can support the program is by properly resourcing it. Leadership must fund the required budget needed to maintain training and protect the time for its employees to complete it during working hours. The completion of this program should also be tied to performance expectations. When employees understand that training is a requirement and can't be overlooked, the company is now protected from future penalties or violations that come with non-compliance. By committing to these resources, leadership demonstrates the importance of the SATE program and that it's a priority rather than an optional exercise.

E. The two failures that TeleMedica faces are the authentication failure and the usage of the previously banned SSL 2.0 protocol. The first failure is authentication. TeleMedica had its employees rely solely on passwords with forced 90-day rotations and no multifactor authentication. This policy violates HIPAA Security Rule access control and NIST SP 800-63B (National Institute of Standards and Technology, 2017). Failing to meet these known security standards and legal regulations leaves the company liable for security violations that need to be fixed to continue to operate its business. To correct this, the SATE program will have required training videos that will educate employees on how they can begin using multifactor authentication, create strong passwords, and protect their credentials from theft. Training employees on these practices will keep the company in line with HIPAA and NIST standards.

The second failure is weak data transmission security. TeleMedica uses a very outdated protocol named SSL 2.0, which was prohibited back in 2011 by the Internet Engineering Task Force (IETF) through RFC 6176 due to its security weaknesses. Because it still uses this protocol, both its business data and its patient data are left vulnerable to attacks, which violates HIPAA Security Rule transmission security. To correct this, the SATE program will have required training videos and simulations that will ensure employees use company-approved encrypted channels when transmitting patient data. This kind of training will keep TeleMedica's transmission of electronic protected health information compliant with the HIPAA Security Rule and ensure employees are knowledgeable about what channels are approved for patient data.

E2. The two proactive security measures I propose for TeleMedica to prevent future incidents are phishing awareness with simulations and secure data handling training. The first proactive security measure is phishing awareness and simulation training. This training will help employees avoid, recognize, and report phishing attempts before any information is

compromised. Although TeleMedica has not experienced a phishing-related failure, phishing is one of the most common attacks against healthcare companies, so having these proactive measures in place is necessary. Because TeleMedica employees are handling sensitive health information daily, a single successful phishing attack could compromise patient and employee data.

As for the second proactive security measure, data handling training, this will reinforce TeleMedica's data classification system by teaching employees how to correctly label documents from public to restricted, store restricted data in approved locations, and follow proper procedures for disposing of unneeded data. Since the majority of TeleMedica's sensitive data is made of patient health records, making sure employees are trained to consistently follow these procedures will prevent any exposure of consumers' protected health information.

E3. The main objective behind phishing awareness with simulation training is to help TeleMedica employees reduce the click rate of simulated phishing emails to below 6% within twelve months of the program's launch. Because TeleMedica employees interact with protected health information daily, reducing successful phishing attempts directly lowers the overall risk of compromising patient records to attackers.

The second objective, for the secure data handling training, is for TeleMedica to achieve at least 90% employee compliance with its data procedures on handling and classifications within twelve months of the program's launch (verified through the quarterly audits). Once this objective has been met, it ensures that restricted patient data is consistently labeled and stored in the secure data vault.

E4. The phishing awareness training will cover four main key topics. First, employees will learn how to identify suspicious phishing emails containing urgent language and mismatched links. Second, it will cover the most common social engineering tactics made to healthcare companies such as attackers impersonating roles with certain kinds of access controls such as executives and IT staff members. Third, the training will cover how to verify unusual or suspicious requests through a separate communication channel. Last, the training will cover TeleMedica's reporting procedure for suspicious emails, which are sent to the Security Operations Center (SOC).

The secure data handling training covers four key topics. First, employees will learn about the four data classification labels that TeleMedica follows: public, internal, confidential, and restricted (TeleMedica, n.d.). Second, employees that go through this training will understand

how to handle data according to the specific requirements of each classification label. Third, the training will teach how to store sensitive data in approved storage locations, such as the secure data vault, and how to securely transmit the data. Fourth, when data is no longer needed, employees will learn exactly how to properly dispose of this data by using the company's enterprise-approved data destruction tool.

E5. Once employees complete the phishing training, they are expected to take several required actions on the job. First and foremost, employees will be aware of what phishing attempts look like, and they'll be hesitant to click on any links without first hovering over them and inspecting the sender's address for any signs of spoofing. Whenever an employee receives an unusual or urgent request, they will verify it through a separate channel before doing anything. All employees will learn that they shouldn't enter their credentials on any page they land on that was redirected from their email. Lastly, if any suspicious emails are identified by an employee, they will be responsible for reporting them to the Security Operations Center by following TeleMedica's reporting procedures.

There are several actions that employees must follow after completing the secure data handling training. Employees must assign the proper classification label on any new documents that are created based on the sensitivity of its contents. For example, restricted data that includes sensitive information about patient health records must be stored only in the secure data vault and transmitted only through approved encrypted channels. Once data is no longer needed, employees must dispose of it promptly using the company's enterprise-approved destruction tool. If employees ever step away from their computers, they must also lock their screens to prevent any unauthorized access to sensitive information.

E6. The training method for phishing awareness will be delivered through an online interactive portal, and it will be done quarterly. During these waiting periods between training, employees will receive simulated phishing emails that will test their competence behind the training they completed. Employees can complete this training at any time regardless of where they work.

The form of training for secure data handling will be delivered by an in-person instructor during new hire onboarding sessions, giving employees the opportunity to learn the procedures directly. This is refreshed annually through online scenario-based exercises that teach them how to properly label, store, and dispose of data. This format of training will give employees a thorough understanding of how the procedures are done from the very start and have a refresher every year.

E7. The phishing awareness training will be measured through several metrics. The first and primary metric will be tracking the simulated phishing emails by click rate. Monitoring this number shows whether employees are meeting the required expectations. The company will also track the report rate of these simulated phishing emails and see the average amount of time it takes for employees to submit these reports. Tracking these reports will allow TeleMedica to see whether the training is resonating with its employees. Last, employees will receive scores based on their performance, and those scores can be reviewed by employees with written explanations of where they need to improve.

As for the secure data handling training, this will be measured every quarter during TeleMedica's quarterly audits. Once every quarter a complete diagnosis of the data will be done that will consist of gathering the data and seeing how many of the labels are correctly classified and if they are being stored in the correct locations. The metric that will be tracked is the overall compliance objective, ensuring that these audit results meet expectations. TeleMedica will monitor data-handling incidents each quarter. A downward trend over the year signifies that training is helping employees reduce mistakes. Conversely, an upward trend may signal that training adjustments are needed to improve these results.

F. The first mechanism is a post training survey that employees fill out after each session is completed. This will ask employees for their honest opinion on the material and employees are able to share what they found unclear or useful and they can also give their own rating on how easy or difficult the entire training was to understand. TeleMedica will look at these survey results every quarter and use them to revise any modules that score poorly, keeping the training program effective over time.

The second mechanism is a complete review of the entire program's metric data which includes the phishing simulation click rates, assessment scores, performance data, and quarterly audit findings. This data is analyzed to identify the areas employees tend to struggle with the most. The weakest areas are given additional revisions for the next training cycle, allowing TeleMedica to improve the program continuously based on measurable results.

References

European Union. (2016). *Regulation (EU) 2016/679 (General Data Protection Regulation)*. Official Journal of the European Union. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>

National Institute of Standards and Technology. (2017). *Digital identity guidelines: Authentication and lifecycle management* (NIST Special Publication 800-63B). U.S.

Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-63b>

TeleMedica. (n.d.). *TeleMedica information security policy*. Western Governors University.

Turner, S., & Polk, T. (2011). *Prohibiting Secure Sockets Layer (SSL) version 2.0* (RFC 6176). Internet Engineering Task Force. <https://doi.org/10.17487/RFC6176>

U.S. Department of Health and Human Services. (2013). *Summary of the HIPAA Security Rule*. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>

U.S. Department of Health and Human Services. (2017). *HITECH Act enforcement interim final rule*. <https://www.hhs.gov/hipaa/for-professionals/special-topics/hitech-act-enforcement-interim-final-rule/index.html>